

Guía metodológica de la Encuesta COBIT 2019 de Ciberseguridad

Basada en los principios de COBIT 2019, su área de enfoque de seguridad de la información y metodologías de evaluación de madurez.[web:18][web:21][web:29][web:44]

1. Propósito de la encuesta

La encuesta persigue tres fines esenciales:

- Medir el nivel de implantación práctica de los procesos de gobierno y gestión de ciberseguridad inspirados en COBIT 2019 (EDM, APO, BAI, DSS, MEA).[web:18][web:39]
- Obtener una foto comparativa entre organizaciones, sectores y países, utilizando una taxonomía común de objetivos y prácticas.[web:24][web:50]
- Alimentar modelos de Índice Global de Madurez (IGM) y de ROI de iniciativas de ciberseguridad, para orientar decisiones estratégicas.[web:29][web:44]

2. Referencias normativas y conceptuales

La encuesta se apoya en:

- COBIT 2019 – Framework: Introduction and Methodology (ISACA).[web:18][web:39]
- COBIT 2019 – Governance and Management Objectives (ISACA).[web:18][web:39]
- COBIT 2019 – Information Security Focus Area.[web:21][web:18]
- Estudios académicos sobre evaluación de seguridad con COBIT 2019 e ISO 27001.[web:24][web:44]
- Propuestas de evaluación de madurez COBIT 2019 mediante escalas 0-5.[web:29][web:50]

No se pretende sustituir marcos específicos (ENS, NIS2, ISO 27001, NIST CSF), sino ofrecer un **esqueleto de gobierno** que los conecte y ordene.

3. Universo de estudio y unidad de análisis

- Universo: organizaciones medianas y grandes con operaciones en España, preferentemente en sectores regulados o críticos.
- Unidad de análisis: la organización (no el individuo). En grupos multinacionales, se recomienda responder a nivel filial/país.
- Respondentes: perfiles con visión transversal de ciberseguridad y TI (CISO, CIO, responsables de riesgo/compliance, directivos de negocio con cartera digital).

4. Estructura de la encuesta

La encuesta se estructura en siete bloques principales más una autoevaluación de madurez:

1. Datos generales (sector, tamaño, alcance geográfico, rol).
2. Gobierno y optimización del riesgo (EDM03).
3. Gestión del riesgo de TI (APO12).
4. Seguridad gestionada / SGSI (APO13).

5. Gestión de cambios de TI (BAI06).
6. Servicios de seguridad (DSS05).
7. Continuidad del servicio (DSS04).
8. Monitorización, evaluación y mejora (MEA01-03).
9. Autoevaluación de madurez global (escala 0-5).

Cada ítem se formula para que pueda traducirse a **indicadores cuantificables** de implantación y madurez.

5. Escalas de respuesta y codificación

5.1. Tipos de preguntas

- Preguntas de frecuencia: miden periodicidad (nunca, ad hoc, anual, trimestral...).
- Preguntas de cobertura: estiman porcentajes de sistemas, procesos o acciones (rangos 0-20 %, 21-40 %, etc.).
- Preguntas de nivel de formalización: distinguen entre inexistencia, práctica informal, proceso definido, proceso integrado.
- Preguntas de madurez autoevaluada: escala 0-5 inspirada en COBIT 2019.[web:29][web:44]

5.2. Codificación recomendada

Para análisis cuantitativo, se sugiere asignar valores numéricos:

- Escalas de frecuencia: 0 (nunca) a 4 (máxima frecuencia).
- Escalas de cobertura: 1 (0-20 %) a 5 (81-100 %).
- Formalización: 0 (inexistente) a 4 (integrado).
- Madurez global: 0-5 directamente.

Esta codificación permitirá el cálculo del **IGM** y otros índices derivados.

6. Índice Global de Madurez (IGM) – Nivel conceptual

El IGM pretende sintetizar en un solo valor el estado de la organización en ciberseguridad desde la óptica COBIT. Se define conceptualmente como:

$$[\text{IGM} = \sum_{d \in \text{Dominios}} w_d \cdot M_d]$$

donde:

- (d) son dominios COBIT relevantes (Gobierno, Riesgo, Seguridad, Cambios, Servicios, Continuidad, Monitorización).
- (w_d) es el peso del dominio (d) (según criticidad o sector).
- (M_d) es la puntuación normalizada de madurez en el dominio (d) (0-5).

La guía de cálculo detallada se proporciona en la **Plantilla de Excel** descrita en otro documento.

7. Enfoque sobre ROI en ciberseguridad

Aunque el ROI en ciberseguridad siempre tiene un toque de arte, la encuesta permite aproximararlo mediante:

- Indicadores de reducción de incidentes (frecuencia y gravedad) asociados a mejoras concretas (por ejemplo, implantación SOC, refuerzo SGSI).[web:46][web:21]
- Incremento de nivel de cumplimiento y reducción de no conformidades que podrían derivar en sanciones o pérdidas.
- Mejora de tiempos de detección y respuesta (MTTD, MTTR) cuantificable frente a escenarios anteriores.[web:46][web:21]

El ROI puede modelarse como:

$$\left[\begin{array}{l} \text{ROI} = \frac{\text{Beneficios estimados (ahorros, pérdidas evitadas)}}{\text{Inversión acumulada en}} \\ \text{iniciativas de seguridad} \end{array} \right]$$

Utilizando variables derivadas de la encuesta (por ejemplo, número de incidentes graves antes/después, reducción del tiempo de parada, etc.).

8. Aplicación comparativa (nacional e internacional)

La encuesta ha sido diseñada para:

- Permitir comparar sectores dentro de un país (p.ej. sanidad vs energía vs administración pública).
- Alinear resultados con índices internacionales como el National Cyber Security Index (NCSI) y otros, mediante mapeos de dominios COBIT.[web:28][web:43]
- Facilitar la elaboración de informes país donde se representen niveles medios de madurez por dominio y se comparen con valores de referencia.

9. Recomendaciones de uso práctico

- Pilotaje: realizar un piloto con un conjunto reducido de organizaciones para ajustar redacción y tiempos de respuesta.
- Confidencialidad: garantizar el tratamiento confidencial de las respuestas para obtener información realista.
- Retroalimentación: ofrecer a los participantes un informe de retorno con su posición relativa respecto al sector, incentivando la participación.
- Periodicidad: repetir la encuesta (por ejemplo, anual) para observar tendencias y evaluar el impacto de las estrategias de ciberseguridad.

10. Tono y cultura de respuesta

El ligero tono irónico de algunas opciones de respuesta no busca ridiculizar, sino ofrecer una **auto-reflexión honesta** sobre la distancia entre el discurso y la práctica. Si una respuesta provoca una sonrisa incómoda, probablemente está haciendo su trabajo.

Fin de la guía metodológica.